



# State of Ohio Administrative Policy

## Vulnerability Management

IT-20

Information Technology

Effective:

November 20, 2024

Issued By:

Kathleen C. Madden, Director

### I. Purpose

The purpose of this policy is to provide statewide **Vulnerability** management requirements that will allow for the consistent identification, prioritization, and **Remediation** of known security Vulnerabilities across all **Agency-Managed Information Systems** and **Agency-Managed System Assets**. This policy also establishes a statewide security Vulnerability severity rating methodology.

The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication 800-53, "Security and Privacy Controls for **Information Systems** and Organizations," **Risk Assessment** (RA) and System and Information Integrity (SI) family identifiers and control numbers are provided in parentheses next to requirements, where applicable.

### II. Scope

This policy applies to all state agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies).

### III. Policy

The Department of Administrative Services (DAS) Office of Information Security and Privacy (OISP) is designated as the central authority responsible for statewide identification and communication of security Vulnerabilities to the Agencies. Agencies must maintain a Vulnerability management program. As part of the program the Agency must define, document, implement, and maintain the processes and procedures required to meet the requirements of this policy as well as Ohio IT Standard ITS-SEC-03, "Vulnerability Management."

- A. **Vulnerability Identification (RA-5)**: The DAS OISP, in collaboration with Agencies, shall routinely monitor and scan all Agency-Managed Information Systems and Agency-Managed System Assets for Vulnerabilities.
- B. **Vulnerability Severity Ratings Methodology**: DAS OISP and Agencies must prioritize and address security Vulnerabilities in accordance with the severity ratings published in the ***NIST National Vulnerability Database (NVD)***, utilizing the ***Common Vulnerability Scoring System (CVSS)***.
- C. **Vulnerability Remediation (RA-5 and SI-2)**: Security Vulnerabilities, as identified by DAS OISP and Agencies, must be Remediated in a timely manner by Agencies through the application of patches, configuration changes, replacing or removing software, or coding changes in accordance with the requirements outlined in Ohio IT Standard ITS-SEC-03, "Vulnerability Management."

#### IV. Definitions

- A. Agency-Managed Information Systems. Information Systems that are controlled or administered by Agencies. These Information Systems may also be operated or hosted by third parties on behalf of Agencies.
- B. Agency-Managed System Assets. **Systems Assets** that are controlled and administered by Agencies. These System Assets may also be operated or hosted by third parties on behalf of Agencies.
- C. Common Vulnerability Scoring System (CVSS). An open framework for communicating the characteristics and severity of software Vulnerabilities. CVSS consists of four metric groups: Base, Threat, Environmental, and Supplemental.
- D. Information Systems. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (e.g., servers, workstations, networking components).<sup>1</sup>
- E. National Institute of Standards and Technology (NIST) National Vulnerability Database (NVD). The U.S. government repository of standards-based Vulnerability management data. This data enables automation of Vulnerability management, security measurement, and compliance. The NVD includes databases of security checklist references, security-related software flaws, product names, and impact metrics.<sup>2</sup>

---

<sup>1</sup> "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

<sup>2</sup> National Institute of Standards and Technology (NIST) Information Technology Laboratory National Vulnerability Database (NVD), 22 March 2024, <<https://nvd.nist.gov/>>.

- F. Remediation. The neutralization or elimination of a Vulnerability or the likelihood of its exploitation.<sup>3</sup>
- G. Risk Assessment. The process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the state, resulting from the operation of a system.<sup>4</sup>
- H. System Assets. Information, hardware, software, or services, required to support Agency business, and identified during the Risk Assessment process as assets that need to be protected.
- I. Vulnerability. Weakness in an Information System, system security procedures, internal controls, or implementation that could be exploited by a threat source.<sup>5</sup>

## V. Authority

ORC 125.18

## VI. Resources

| Document Name                                                                                                                                                 | Location                                                                                                                                                                                                                                      |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Center for Internet Security (CIS) Critical Security Control 7: Continuous Vulnerability Management                                                           | <a href="https://www.cisecurity.org/controls/continuous-Vulnerability-management">https://www.cisecurity.org/controls/continuous-Vulnerability-management</a>                                                                                 |
| Cybersecurity and Infrastructure Security Agency (CISA) Binding Operational Directive 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | <a href="https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-Vulnerabilities">https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-Vulnerabilities</a> |
| Common Vulnerability Scoring System (CVSS)                                                                                                                    | <a href="https://www.first.org/cvss">https://www.first.org/cvss</a>                                                                                                                                                                           |
| Multi-State Information Sharing & Analysis Center (MS-ISAC)                                                                                                   | <a href="https://www.cisecurity.org/ms-isac">https://www.cisecurity.org/ms-isac</a>                                                                                                                                                           |
| NIST National Vulnerability Database (NVD)                                                                                                                    | <a href="https://nvd.nist.gov">https://nvd.nist.gov</a>                                                                                                                                                                                       |

<sup>3</sup> Schaffer, Kim, Peter Mell, Hung Trinh, and Isabel Van Wyk, "NIST Special Publication 800-216, Recommendations for Federal Vulnerability Disclosure Guidelines," U.S. Department of Commerce National Institute of Standards and Technology, May 2023, <<https://csrc.nist.gov/pubs/sp/800/216/final>>.

<sup>4</sup> "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

<sup>5</sup> *Ibid.*

| Document Name                                                                                                                                                                                | Location                                                                                                                                                                                                                                                                                                                        |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NIST Special Publication 800-53, Security and Privacy Controls for Information Systems and Organizations (Risk Assessment (RA) and System and Information Integrity (SI) Family of Controls) | <a href="https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf">https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf</a>                                                                                                                                                             |
| NIST Special Publication 800-40, Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology                                                                        | <a href="https://csrc.nist.gov/pubs/sp/800/40/r4/final">https://csrc.nist.gov/pubs/sp/800/40/r4/final</a>                                                                                                                                                                                                                       |
| Ohio IT Standard ITS-SEC-02 Enterprise Security Controls Framework                                                                                                                           | <a href="https://das.ohio.gov/technology-and-strategy/policies/its-sec-02-enterprise-security-controls-framework">https://das.ohio.gov/technology-and-strategy/policies/its-sec-02-enterprise-security-controls-framework</a>                                                                                                   |
| Ohio IT Standard ITS-SEC-03 Vulnerability Management                                                                                                                                         | <a href="https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards/its-sec-03-vulnerability-management">https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards/its-sec-03-vulnerability-management</a> |
| Open Worldwide Application Security Project (OWASP) Top 10                                                                                                                                   | <a href="https://owasp.org/www-project-top-ten/">https://owasp.org/www-project-top-ten/</a>                                                                                                                                                                                                                                     |

## VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy  
Office of Information Technology  
Ohio Department of Administrative Services  
30 East Broad Street, 39<sup>th</sup> Floor  
Columbus, Ohio 43215  
614-644-6860 | [state.isp@das.ohio.gov](mailto:state.isp@das.ohio.gov)

State of Ohio Administrative Policies may be found online at  
<https://das.ohio.gov/technology-and-strategy/policies>

## VIII. Revision History

This policy must be reviewed no less than every two years and updated as needed.

| Date       | Description of Change |
|------------|-----------------------|
| 11/20/2024 | Original policy.      |